REPORT TECNICO: Simulazione di Phishing e Social Engineering

Analista: Victor Rosati

Progetto: TweniSpirit Scam Simulation

Data: 09 Gennaio 2026

Categoria: GRC & Social Engineering

---

1. Executive Summary

L'attività descritta consiste in una simulazione formativa di un attacco di phishing mirato (Spear Phishing). L'obiettivo è dimostrare come l'efficacia di un attacco non dipenda necessariamente da exploit tecnici, ma dalla manipolazione psicologica dell'utente tramite tecniche di **Social Engineering**.

Attraverso il brand fittizio **TweniSpirit**, è stato analizzato come stimoli di autorità e opportunità professionale possano indurre un utente a interagire con link potenzialmente pericolosi e a fornire credenziali sensibili.

2. Metodologia e Strumenti

- **Brand Identity:** Logo creato tramite *Nano Banana AI* per conferire credibilità visiva.
- **Web Development:** Landing page sviluppata con *Claude AI* (hosting su piattaforma Leadfather).
- **Vettore di attacco:** Email con approccio "Talent Scouting".
- **Compliance:** Nessun dato reale è stato raccolto; l'attività è stata condotta a scopo puramente didattico in ambiente controllato.

3. Analisi dell'Attacco (Kill Chain)

Fase 1: Il Vettore di Attacco (E-mail Luring)

Per l'aggancio iniziale è stata strutturata una comunicazione e-mail che simula una proposta di collaborazione professionale. Il testo è stato studiato per massimizzare il **Click-Through Rate (CTR)** sfruttando leve psicologiche specifiche.

Dettagli Tecnici dell'E-mail:

- **Oggetto:** Selezione profilo – Collaborazione TweniSpirit
- **Mittente simulato:** contact@twenispirit.io (Dominio plausibile non verificato)
- **Testo della comunicazione:**

*“Ciao, siamo **TweniSpirit**, un’agenzia creativa che lavora con brand emergenti e profili ad alto potenziale nel mondo social e digital. Il tuo profilo è stato **selezionato dal nostro team** per una possibile collaborazione legata a progetti di visibilità e crescita organica su Instagram.*

Per completare la prima fase di valutazione, ti chiediamo di accedere alla nostra area di onboarding e confermare alcune informazioni di base sul tuo account.

*👉 **Accedi alla piattaforma TweniSpirit:***

[LINK: https://app.leadfather.io/v2/preview/LjiN5firzHnb862ber8t?notrack=true]

*La selezione resterà attiva per **24 ore**. In assenza di conferma, il profilo verrà rimosso dalla shortlist.*
*Grazie per il tempo dedicato, **TweniSpirit – Talent & Growth Team** “*

Fase 2: Analisi del Link e Landing Page

Il link contenuto nell'email punta a un dominio esterno utilizzato per mascherare la reale intenzione dell'attaccante e creare un ambiente visivo coerente con il brand.

- **URL:** https://app.leadfather.io/v2/preview/LjiN5firzHnb862ber8t?notrack=true
- **Tecnica:** Offuscamento tramite piattaforma di terze parti e utilizzo di un countdown per indurre urgenza.

TweniSpirit

Profilo Selezionato

⚠ SELEZIONE ATTIVA PER TEMPO LIMITATO

La tua finestra di conferma scadrà tra:

03 MINUTI

24 SECONDI

✓ TALENT SELECTION 2026

Il Tuo Profilo È Stato Selezionato

Dopo un'attenta analisi del nostro team, il tuo account Instagram è stato identificato come **candidato ideale** per una collaborazione strategica esclusiva con TweniSpirit.

97%	24h	Elite
MATCH SCORE	PER CONFERMARE	COLLABORAZIONE

Strategia Custom
Piano personalizzato per il tuo profilo

Crescita Organica
Aumento follower e engagement reali

Content Premium
Contenuti professionali di alta qualità

Partnership Esclusive
Accesso a brand e opportunità

500+	+250%	97%
Profili Collaborati	Crescita Media	Tasso Successo

Cosa Dicono I Profili Che Abbiamo Trasformato

FC Francesca Carletti
@francesca_wellness · Wellness Coach
★★★★★

"Ero scettica, pensavo fosse l'ennesima promessa vuota. In 2 mesi sono passata da 8.000 a 47.000 follower. Ma il vero game-changer? ***Ho triplicato i clienti del mio programma coaching****. Non parliamo di numeri finti, parliamo di fatturato reale. TweniSpirit ha capito esattamente come posizionarmi."*

+39K	320%	€47K
Follower in 60gg	Engagement Rate	Revenue Extra

MD Marco Di Stefano
@distefano_realestate · Agente Immobiliare
★★★★★

"Avevo provato 3 agenzie prima. Zero risultati. TweniSpirit in 90 giorni mi ha portato ***12 clienti high-ticket*** *direttamente da Instagram. Non sto parlando di like, sto parlando di contratti firmati. Il mio profilo è diventato una macchina di acquisizione clienti. Investimento rientrato dopo la prima vendita."*

12	+28K	€180K
Clienti Acquisiti	Follower	Commissioni

SV Sofia Valentini
@sofia.jewelry · Jewelry Designer
★★★★★

"Pensavo di dover fare Reels ridicoli per crescere. TweniSpirit mi ha fatto capire che l'eleganza vende di più. Hanno riposizionato tutto il mio brand in chiave luxury. Risultato? ***Da 15K a 89K follower in 4 mesi****, e soprattutto: collaborazioni con*

Accedi Con Il Tuo Instagram

Collega il tuo account Instagram per confermare la tua partecipazione alla selezione e sbloccare l'accesso alla collaborazione.

Connetti con Instagram →
Accedi per confermare la partecipazione

🔒 Connessione sicura tramite OAuth. Non memorizziamo la tua password.
Utilizziamo solo dati pubblici del profilo per valutare la tua candidatura.

Cosa Accade Dopo Il Login?

1. Analizziamo il tuo profilo Instagram in tempo reale
2. Riceviamo i tuoi dati di contatto per comunicazioni ufficiali
3. Il team ti contatta entro 24h con proposta personalizzata
4. Call strategica per discutere obiettivi e piano d'azione

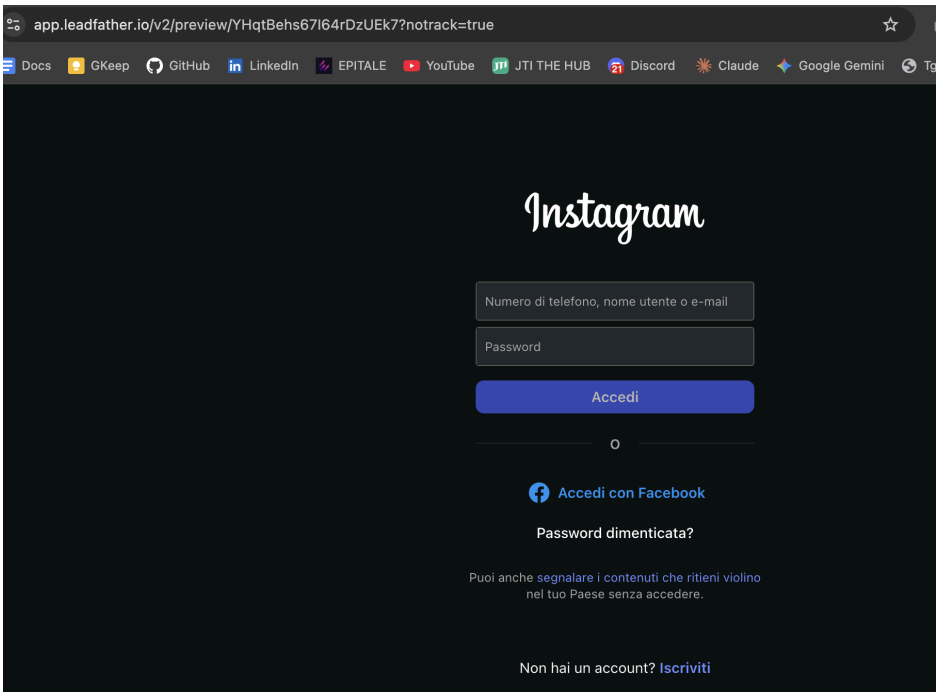
Cosa Succede Dopo?

1. **Valutazione Approfondita** – Analizziamo il tuo profilo nel dettaglio
2. **Strategia Personalizzata** – Creiamo un piano su misura per te
3. **Call Strategica** – Discutiamo obiettivi e modalità di collaborazione
4. **Inizio Partnership** – Avviamo il progetto di crescita

Fase 3: Credential Harvesting & Redirect

L'ultima fase prevede l'atterraggio su una pagina di login che replica fedelmente l'interfaccia di **Instagram**.

- **Tecnica:** Visual Spoofing tramite clonazione del front-end (HTML/CSS) del brand originale.
- **Obiettivo:** In uno scenario reale, questa pagina servirebbe a intercettare Username e Password. Per finalità etiche, nella simulazione il sistema valida il concetto di "Account Takeover" tramite un redirect sicuro.



4. Tecniche di Social Engineering Utilizzate

1. **Lusinga:** Far sentire l'utente "scelto" per aumentare la predisposizione al click.
2. **Autorità:** Uso di un linguaggio corporate e di un'identità visiva curata.
3. **Scarcity (Urgenza):** Il timer di 24 ore riduce il tempo di analisi critica dell'utente, portandolo a ignorare le anomalie dell'URL.
4. **Mobile Optimization:** La pagina è ottimizzata per smartphone, dove il controllo dei certificati e dei domini è meno immediato per l'utente medio.

5. Conclusioni

L’esercizio evidenzia come il fattore umano rimanga l'anello più debole della catena di sicurezza. La prevenzione non può essere solo tecnologica, ma deve passare attraverso la **Security Awareness**: educare l'utente a identificare i segnali di manipolazione comportamentale e a verificare sempre la sorgente delle richieste di dati sensibili.